

Offensive Security in the AI Transformation

Executive brief — why the operating model must shift now, and what we are asking the executive team to endorse.

The thesis

- Within twelve months, hundreds of AI-enabled and self-developed applications will exist across the enterprise — many handling PHI, many deploying outside the formal SDLC.
- If offensive security keeps operating as a pre-deployment review function, it will be routed around. If it becomes the empirical truth function for AI risk — the team that proves what does and does not work — it becomes a strategic partner to the transformation.
- In healthcare, an AI-mediated PHI exposure or a manipulated clinical-adjacent system carries breach-notification, HIPAA, FDA-adjacent, and patient-safety consequences. The window to shape the model is now.

What we will do

- **Build the paved road** — sanctioned LLM gateway, curated MCP registry, managed agent runtime, secure-by-default templates. The secure path becomes the easy path; adoption is the enforcement mechanism.
- **Risk-tier every AI initiative** — four tiers anchored on PHI, decision impact, integration footprint, and user population. Human depth on Tier 1-2; automated assurance on Tier 3-4.
- **Validate continuously, not once** — replace pre-deploy review with continuous post-deploy validation, threat hunting, and control testing across the five offensive security functions.
- **Demonstrate before we ask for more** — the Phase 1 demonstration red team exercise reframes every later budget conversation in terms of avoided harm, not abstract risk.
- **Report quarterly** — state-of-AI-security to the cyber exec team and risk committee, drawn from unified AI telemetry across gateway, MCP farm, and agent runtime.

What we need from the executive team

- **Endorse the operating-model shift** — gatekeeper → embedded advisor and continuous validator; risk-tiered engagement as the enterprise standard.
- **Sponsor the sanctioned AI infrastructure** — gateway, MCP farm, agent runtime, AI-aware SDLC, network provisioning — in conversations with platform engineering and AI governance.
- **Ratify the RACI** — offensive security owns the discipline; platform engineering operates the controls; business owners own tiering inputs and risk acceptance.
- **Authorize Phase 1** — within existing headcount and operating budget, with funded training and tooling proof-of-concepts.
- **Provide air cover** — active sponsorship in AI transformation forums, AI governance, and BU leader conversations, positioning offensive security as the empirical truth function for AI risk.
- **Commit the cadence** — quarterly state-of-AI-security report to cyber exec team and risk committee, beginning end of Phase 1.

What success looks like — twelve months

Velocity preserved	Risk made visible	Footing established
Citizen developers ship AI tools through a sanctioned path faster and cleaner than shadow alternatives. Hard pre-deploy gates apply only to Tier 1.	Every prompt, tool call, and agent decision flows through unified telemetry. PHI egress, prompt-injection, and agent drift are detectable, attributable, reportable.	Offensive security is a named participant in AI governance, AI infrastructure decisions, and quarterly board reporting — not a downstream reviewer.

Why this proposal, and why now

- Phase 1 is executable inside existing headcount — endorsement, not funding, is the unblocking decision.
- The Phase 1 demonstration red team is the single highest-leverage move; it reframes every later investment in terms of avoided harm.
- The longer AI governance is set without offensive security at the table, the more expensive it is to insert later.